

Designing a Cybersecurity Program for a FinTech Startup [Group]

Group 1: Remi Adekunle, Akshay Aravind, Cortland Brown, Sabrina Tan

Northeastern University

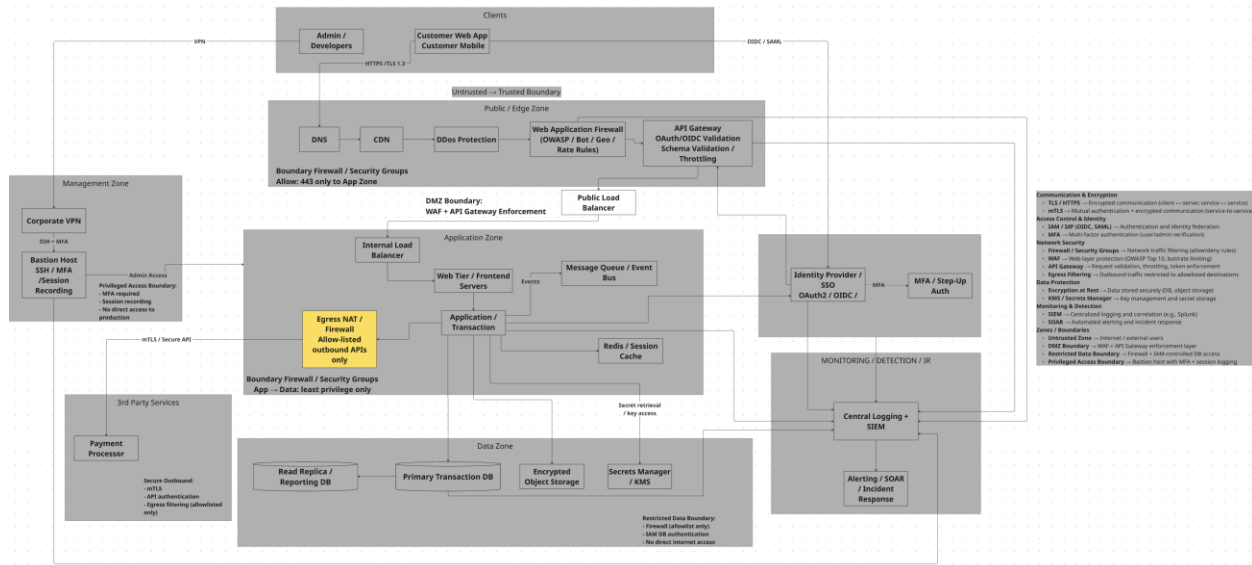
DAMG7350: Systems and Cybersecurity Fundamentals

April 19, 2026

Table of Contents

System Architecture.....	3
Threat Model.....	6
Risk Register.....	8
Risk Likelihood Table.....	8
Risk Impact Table	9
Risk Rating Table	10
Risk Register with Justification	10
IAM Least-Privilege Design.....	15
SIEM Monitoring & Detection Strategy.....	16
Data Ingestion	16
Detection Use Case 1: Unauthorized IAM Role Changes or Account Modifications.....	17
Detection Use Case 2: Unusual Outbound Network Traffic Suggesting Data Exfiltration.....	18
Detection Use Case 3: High-Volume Failed Logins Indicating Credential Stuffing.....	18
Conclusion	19
Incident Response Workflow.....	19
Incident Response Lifecycle:	19
Playbook: Compromised IAM Credential	20
Future Improvements & Recommendations:	22
References.....	23

System Architecture



Our FinTech environment will rely on principles of defense-in-depth, least-privilege access, and security-by-design to protect confidential financial and transactional data. The system will be designed to reduce the surface area of potential attack vectors and minimize lateral movement should a breach occur. This results in the system having multiple zones, allowing security controls to be enforced at each layer through boundary protection, secure communication protocols, and centralized identity and monitoring systems.

To ensure segregation within each zone and to control access between components of the application systems, the architecture is divided into clearly defined zones. The Public Zone serves as the point of entry for all external traffic. Components within the Public Zone will provide DNS and CDN services, DDoS protection, Web Application Firewall (WAF), and API Gateway functionality to filter or validate requests before sending them to internal systems. The WAF will protect against common web-based attacks (such as SQL injection and cross-site scripting). The API Gateway will provide authentication, validate requests from external sources,

and rate-limit clients based on specified criteria. The Public Zone represents the untrusted boundary where traffic is crossing from uncontrolled external entities to controlled infrastructure.

In the application zone, web/app tier, application/transaction services, message queuing, and caching layer are all present. This is where business logic and transaction processing occur; financial operations, user requests, and downstream system interactions are handled by the application services. The identity provider integrated to provide OIDC/SAML-based authentication services to users of the application services enforces MFA for user/service access prior to processing any sensitive operation. The DMZ boundary separates the application zone from the public zone; furthermore, the WAF and API gateway allow only validated/authenticated traffic to traverse it.

The data zone includes the following items: primary transaction database, read replica, encrypted object storage, and KMS/Secrets manager. Since it contains the most sensitive financial/customer information, access to this zone is restricted by defined data boundaries through firewall rules that permit only application-layer access, IAM-based database authentication, and no direct internet access. Data is encrypted at rest; TLS is also required when establishing database connections for confidentiality and integrity.

Management Zone allows administrators to securely connect to the system through a bastion host, which restricts administrative access via MFA (multi-factor authentication) and records all sessions to provide accountability and enable tracking for administrative users. The Management Zone also establishes the Privileged Access Boundary (PAB), which separates administrative access from standard user traffic and ensures strict control of administrative access.

The Monitoring Zone provides centralized logging and alerting/incident response services from the SIEM; logs from all key components of the system are aggregated in the SIEM for correlation and analysis. As a result, real-time detection of malicious activity is possible, and the full incident response lifecycle (detection, isolation, and correction) can be performed. Third-party services, such as payment processors, are accessed through secure egress connections using mTLS, API authentication, and egress filtering to limit access to only those approved by external parties.

Security is built into the system at each stage of the process. All communications use secure protocols, with HTTPS and TLS as the primary means of securing connections between clients and servers, as well as between internal services. The mTLS (Mutual Transport Layer Security) protocol is used to secure service-to-service and outbound API communications (to external services). Administrators will use an SSH connection with multi-factor authentication (MFA) to access the system. OIDC and SAML will be used for authentication and identity federation between trusted and untrusted parties. The use of these protocols will provide assurances of confidentiality, integrity, and authentication for all communication paths.

The architecture has several layered security boundaries that regulate traffic flow through the system and reduce risk. The Untrusted → Trusted Boundary represents the separation of the external user from the internal infrastructure. The WAF and API Gateway enforce the DMZ Boundary by filtering and validating all requests from external sources. Data can be accessed only by authorized users in the Data Zone, as defined by the firewall rules and IAM controls within the Restricted Data Boundary. The Privileged Access Boundary is enforced using MFA and a bastion host to restrict administrative access. The Secure Outbound Boundary is enforced through egress filtering and secure APIs to restrict traffic flow from within the system to outside

it. These layers of security will ensure that each step of the lifecycle authenticates incoming and outgoing traffic.

KMS (Secrets Manager) provides a secure way to store and manage secret information, such as database credentials and API keys, as well as encryption keys used to protect data stored on disk in databases and storage systems. Application services dynamically retrieve secrets from KMS at runtime, rather than storing them within code. KMS provides the encryption keys necessary to protect data at rest.

This FinTech architecture delivers a secure and scalable foundation for a transaction processing system by utilizing multiple security boundaries, along with enforcing secure communication protocols, and providing centralized identity management and extensive monitoring capabilities. The application of the principle of least privilege, combined with the implementation of multiple security boundaries, reduces risk exposure while maintaining the confidentiality and integrity of sensitive transaction data.

Threat Model

Threat	How It Applies	Mitigation Strategies
Spoofing	An attacker impersonates a user or service using stolen credentials or forged tokens. This could allow unauthorized access to the application bypassing the API Gateway. Attackers may also forge or reuse JWT tokens to bypass authentication protocols.	• Enforce MFA through the Identity Provider • Use OIDC/SAML with short-lived tokens and token validation at the API Gateway • Implement mTLS for service-to-service authentication

		• Use SIEM to monitor login anomalies
Tampering	Unauthorized modification of data in transit or at rest. An attacker could modify transaction requests between the client and application, tamper data between the application and database, or alter stored financial records if access controls fail.	• Enforce TLS encryption for all communications • Use input and schema validation at the API Gateway • Implement database access controls and least privilege IAM policies • Enable audit logging and integrity monitoring
Repudiation	A user or administrator denies performing an action due to lack of traceability. This includes denying financial transactions, system changes, or actions due to insufficient logging.	• Centralize logs in SIEM • Enable detailed audit logging for application, database, and admin actions • Use session recording on the bastion host
Information Disclosure	Exposure of sensitive data such as customer information, credentials, or financial records. Attackers may exploit misconfigured APIs, intercept unencrypted traffic, or access improperly managed secrets.	• Encrypt data in transit (TLS) and at rest (KMS) • Store secrets securely in Secrets Manager • Enforce RBAC/IAM policies to restrict access
Denial of Service	Attackers overwhelm the system, making it unavailable to legitimate users. This may include flooding the API Gateway, overloading backend services, or launching	• Use CDN and DDoS protection • Implement rate limiting and throttling at the API Gateway

	distributed attacks on public endpoints.	• Deploy autoscaling and load balancing • Monitor traffic spikes
Elevation of Privilege	An attacker gains higher-level privileges, potentially leading to unauthorized admin access and system compromise.	• Enforce least privilege IAM policies across services • Implement role separation and regular access reviews • Monitor privilege escalation attempts

Note. Adapted from “Threat modeling process,” by L. Conklin et al., n.d., OWASP Foundation (https://owasp.org/www-community/Threat_Modeling_Process#stride).

Risk Register

Risk Likelihood Table

Likelihood	Rare (1)	Unlikely (2)	Moderate (3)	Likely (4)	Highly Likely (5)
Likelihood of Occurrence	≤ 5% chance per year	6–20% chance per year	21–50% chance per year	51–80% chance per year	> 80% chance per year or occurs multiple times annually

Note. Data adapted from *SafetyCulture* (2025) by Patricia Guevara,

<https://safetyculture.com/topics/risk-assessment/5x5-risk-matrix>

Risk Impact Table

Impact	Insignificant (1)	Minor (2)	Significant (3)	Major (4)	Severe (5)
People	Minimal impact to data confidentiality, integrity, and availability	Data confidentiality, integrity, and availability exposed for 24-48 hours	Data confidentiality, integrity, and availability exposed for 1-4 weeks	Data confidentiality, integrity, and availability exposed for a month or more	Data confidentiality, integrity, and availability exposed indefinitely
Technical	No impact on financial transactions	Minor impact or delays on financial transactions	Partial system outage with impact on financial transactions	Major system failure with high impact on financial transactions	Complete system failure, downtime, and data loss
Financial	< \$10,000	\$10,000 - \$50,000	\$50,000 - \$500,000	\$500,000 - \$5,000,000	> \$5,000,000
Reputation	Minimal effect on customer trust	Minor or short-lived negative effect on customer trust	Local negative media coverage with impact on customer trust	Regional negative media coverage with impact on customer trust	Widespread loss of customer trust; long-term brand damage
Legal / Compliance	No legal or compliance issues	Minor legal or compliance breach; easy remediation	Legal or compliance breach that requires remediation	Legal or compliance breach that requires formal investigation by authorities	Legal action; heavy financial penalty; criminal charges

Risk Rating Table

Risk Rating	Low	Medium	High	Critical
Likelihood x Impact = Risk Rating	1-4	5-9	10-16	17-25

Note. Data adapted from *SafetyCulture* (2025) by Patricia Guevara,

<https://safetyculture.com/topics/risk-assessment/5x5-risk-matrix>

Risk Register with Justification

Risk ID	Description	Likelihood	Impact	Risk Rating	Proposed Mitigation
R01	Compromise of sensitive financial and customer data due to unauthorized access	Moderate (3)	Severe (5)	15	- Implement MFA for all users - Enforce least privilege access and role-based access controls (RBAC) - Monitor and log user activities to sensitive data - Establish a robust incident response plan
<u>Justification:</u> FinTech companies are major targets for attackers because they often manage sensitive financial and customer data (Moore, 2025). Common attacks include phishing, malware, ransomware, and DDoS. It has a moderate chance of occurring within a single year,					

even with strong existing controls, and can cause severe consequences such as data exfiltration, reputational damage, loss of customer trust, high financial penalties, compliance violations, and potential litigation.

R02	Formal user access reviews are not completed for critical systems with access to financial and customer data	Likely (4)	Major (4)	16	- Identify critical system owners and enforce at minimum annual user access review with documentation of access changes and approvals - Automate access review workflows and flagging of inactive accounts using IGA
-----	--	------------	-----------	----	---

Justification: User access reviews are often overlooked in companies due to operational pressures but are often a requirement for regulatory frameworks such as PCI-DSS and GDPR. It is likely to happen and failure to perform annual access reviews can result in privilege creep and excessive privileges, which can be exploited by outside attackers or insider threats.

R03	Insider threat where employees or contractors may intentionally or unintentionally expose sensitive data	Moderate (3)	Major (4)	12	Require completion of annual security awareness training for all employees around phishing and data protection
-----	--	--------------	-----------	----	--

					• Implement JIT access with zero standing privileges • Implement continuous DLP monitoring for suspicious activity or data exfiltration • Define clear disciplinary actions for violations in policies
<u>Justification:</u> In a 2024 insider threat report, 71% of companies feel moderately vulnerable to insider threats (Cybersecurity Insiders, 2024). It has a moderate chance of occurring as it requires employees or contractors with authorized access, but impact can be major with sensitive data exfiltration or disruption to business operations.					
R04	Misconfigurations that expose internal resources (e.g., default accounts, database) to the public	Likely (4)	Severe (5)	20	• Disable unnecessary ports or services • Automated process to verify configurations and settings in all environments (OWASP, 2025) • Enforce IaC with policy-as-code security checks

					Review storage permissions
<u>Justification:</u> Security misconfigurations are included in the OWASP Top 10:2025, making it one of the most critical vulnerabilities and therefore likely to be exploited. They can cause large scale data breaches. Public exposure can result in severe consequences such as data exfiltration, reputational damage, loss of customer trust, high financial penalties, compliance violations, and potential litigation.					
R05	Third party vendor or supply chain compromise	Moderate (3)	Major (4)	12	- Periodic security and risk assessments for all new and existing third party vendors - Define clear security and breach clauses in contractual agreements (e.g., right to audit, termination procedures)
<u>Justification:</u> Although third party compromises are included in the OWASP Top 10:2025, the organization themselves can implement strong controls to reduce the risk and frequency. During a vendor compromise, the organization may not always be affected. However, the impact can be major including disruptions to business operations, data breaches, data leakage, and compliance violations.					
R06	Potential security vulnerabilities in	Moderate (3)	Major (4)	12	Hire personnel with relevant

	emerging technologies such as AI, blockchain, and ML (Moore, 2025)				knowledge and skillset to implement new technologies • Perform comprehensive testing in an isolated environment prior to deploying to production
<u>Justification:</u> FinTech companies are increasingly using new technologies such as blockchain, AI, and ML, which can introduce integration risks like incompatibility with legacy systems and unexpected vulnerabilities (Moore, 2025). As adoption grows, these technologies become the new targets for attackers as their security maturity is still evolving. If exploited, such vulnerabilities can have a major impact, causing outages, data exfiltration, loss of customer trust, and financial loss.					

IAM Least-Privilege Design

IAM ROLE AND PERMISSION MODEL

Developer ENGINEERING TEAM	Allowed Actions - Read/Write access to test/dev environments - Deploy changes to non-production environments - Read application logs for troubleshooting - Create pull requests	Denied Actions - No access to production environments and databases - No access to production secrets vault - No access to raw data - Cannot approve their own changes and deploy to production	Least Privilege Developers should not have access to raw financial or customer data. They can build and test code, but cannot access production to prevent deployment of untested code, accidental outages, and configuration errors.
Application Server SERVICE ACCOUNT	Allowed Actions - Call only required APIs - Read/Write access to its own database schema only as needed - Read access to specific required secrets	Denied Actions - No human interactive login capability - No administrative permissions unless it is necessary - No access to database schema outside its designated scope	Least Privilege Application service accounts should have minimal access required to fulfill its purpose to prevent excessive privileges and minimize potential attack surface. Write and administrative access should be avoided unless it is required.
Security Engineer SECURITY TEAM	Allowed Actions - Read access to security logs - Read/Write access to IAM policies with necessary reviews - Read/Write access to security tools, such as SIEM alerts and dashboards - Run vulnerability scans	Denied Actions - No access to source code repository - No access to database containing financial and customer data - No access to modify IAM policies without second peer review	Least Privilege Security engineers can monitor and enforce security controls, but should not have access to modify or delete application data and security logs. This prevents them from being able to elevate their own access and cover their tracks.
Database Administrator DATABASE TEAM	Allowed Actions - Execute DDL operations to database schema via JIT access request - Manage database performance and backups - Apply patches and updates after testing	Denied Actions - No access to modify or delete database activity logs - No direct access to encrypted sensitive financial and customer data - No standing privileges to production database	Least Privilege Database administrators (DBA) are restricted to managing and maintaining databases. They have zero standing privileges to production access and temporary elevated access must be approved, reducing the risk of lateral movement and attack surface.
Compliance Manager COMPLIANCE TEAM	Allowed Actions - Read access to audit logs - Read access to IAM policies - Run a compliance report in compliance tool and dashboard	Denied Actions - No access to source code repository - No access to modify security configurations - No access to encrypted sensitive financial and customer data	Least Privilege Compliance Manager should have read-only access to audit reports, IAM configurations, and compliance reports. They should not have write access to any configurations or production data as that would violate SoD principles.

SIEM Monitoring & Detection Strategy

This monitoring plan defines how the FinTech organization will collect, analyze, and correlate security-relevant data using Splunk to detect threats targeting systems that process financial transactions and store sensitive customer data. The plan supports the broader security architecture, threat model, IAM strategy, and incident response workflow by ensuring that all critical security domains produce actionable visibility and can be operationalized within a security operations center (SOC) environment.

Data Ingestion

The monitoring program ingests security event data from identity systems, network infrastructure, applications, endpoints, and data repositories. Identity-related logs include authentication events, MFA usage, failed logins, privilege changes, and role assignments from the organization's identity provider and internal IAM systems. These logs provide the foundation for identity-centric detections, enabling Splunk to correlate user behavior, detect anomalous access, and identify privilege escalation attempts. Field extractions for user, action, target user, and source IP are normalized through Splunk's Common Information Model (CIM) to support cross-domain correlation.

Network monitoring data includes firewall logs, intrusion detection system alerts, VPN access logs, DNS query logs, and internal network flow records such as VPC flow logs. These sources provide visibility into lateral movement, command-and-control activity, and unauthorized data transfers. VPC flow logs in particular provide structured metadata (src_ip, dest_ip, bytes, action, direction) that can be aggregated to detect exfiltration or anomalous communication patterns.

Application log data is collected from financial transaction systems, customer-facing portals, internal APIs, and backend services. These logs capture transaction metadata, HTTP status

codes, authentication outcomes, and business-logic events such as account changes or payment initiation. They are normalized to CIM's Web and Application data models to support detection of fraud, misuse, and automated attacks.

Endpoint and server audit data includes operating system events, process creation, file access, and security agent alerts. These logs support detection of malware, unauthorized tools, and suspicious administrative activity. Database audit logs capture query execution, failed authentication attempts, schema modifications, and privilege changes. Data access logs from storage systems record read, write, and deletion activity involving sensitive customer information.

All security event data is normalized using Splunk's Common Information Model to ensure consistent field naming across identity, network, and application domains. This normalization enables correlation searches that combine multiple data types into a single detection and supports risk-based alerting within Splunk Enterprise Security.

Detection Use Case 1: Unauthorized IAM Role Changes or Account Modifications.

This detection identifies attempts to escalate privileges or modify access pathways within internal systems. It focuses on events such as administrative role changes, permission updates, and account creation. These events are grouped by user and action type to highlight unusual administrative activity. The following sample SPL is structured to support rapid triage by showing actor, action, and target:

```
index=iam_logs action IN ("role_change","permission_change","account_created")  
  
| stats count BY user, action, target_user | where count > 0
```

Technical Rationale: Privilege escalation is a high-impact event in a FinTech environment because it can directly enable unauthorized access to financial systems, customer data, or

transaction workflows. This detection provides a low-noise, high-value signal by focusing on explicit administrative actions rather than behavioral anomalies. It is also easily enriched with lookup tables (e.g., known admin accounts) or baselines (e.g., expected role-change frequency).

Detection Use Case 2: Unusual Outbound Network Traffic Suggesting Data Exfiltration.

This detection identifies systems sending unusually substantial amounts of outbound data. It uses VPC flow logs to aggregate outbound traffic volume by source IP and flags systems that exceed a defined threshold. The following sample SPL is intentionally simple but operationally effective, allowing analysts to quickly identify hosts that may be exfiltrating data:

```
index=vpc_flow_logs direction="outbound" | stats sum(bytes) AS total_bytes BY src_ip  
| where total_bytes > 300000000
```

Technical Rationale: Outbound data volume is a reliable early indicator of data exfiltration, especially when correlated with identity or application activity. While more advanced detections may incorporate baseline data or machine learning, this threshold-based approach provides immediate operational value and can be tuned per environment. It also integrates cleanly with Splunk Enterprise Security's Risk Framework by assigning risk scores to high-volume outbound events.

Detection Use Case 3: High-Volume Failed Logins Indicating Credential Stuffing.

This detection identifies credential stuffing, brute-force login attempts, and early signs of account takeover. It uses web authentication logs to detect high-volume failed logins from a single IP address. The following sample SPL groups failures by source IP and applies a threshold to identify automated attack patterns:

```
index=web_logs status=401 | stats count AS failed_logins BY src_ip  
| where failed_logins > 40
```

Technical Rationale: Credential stuffing is a common attack vector against financial applications due to the high value of compromised accounts. This detection provides a straightforward mechanism for identifying automated login attempts and can be extended with additional logic such as user-agent analysis, geolocation, or correlation with successful logins. It also supports automated response actions such as IP blocking or MFA enforcement.

Conclusion

This monitoring plan provides comprehensive visibility across identity, network, application, endpoint, and data layers. By combining broad ingestion of security event data with targeted detections aligned to real attacker behaviors, the FinTech organization can rapidly identify and respond to threats that could compromise financial transactions or customer data. Splunk's correlation, normalization, and search capabilities enable the security team to detect privilege escalation, data exfiltration, and account takeover attempts with high fidelity and operational clarity.

Incident Response Workflow

Our FinTech business oversees processing financial transactions and storing sensitive customer information. It is important to have a systemized and prompt reaction to security incidents. The standard incident response lifecycle will enable our team to address security incidents successfully.

Incident Response Lifecycle:

Our six-step process of responding to a security incident will be:

- **Detect:** To identify any abnormal activities or automated alerts in our environment, we will constantly be monitoring our environment using SIEM dashboards, VPC flow logs, and IAM logs.

- **Analyze:** The scope of the incident will be analyzed by the security team when the threat is identified. We will know whether the threat is inside the data zone (where valuable customer data is kept) or if the threat is to the public or application networks.
- **Contain:** This will be done by making sure that we contain the threat immediately. This can be done by isolating EC2 instances, blocking bad IPs at the firewall or WAF, or disabling compromised accounts.
- **Eradicate:** Following the containment of the threat, the team will eliminate the source of the breach. This involves deleting infected files, fixing exploited vulnerabilities, and deleting access keys.
- **Recover:** With known clean off-site backups, we will restore the affected systems to normal functioning. The team will be very vigilant of the network in this step to make sure that the attacker does not reappear.
- **Lessons Learned:** The security team will conduct a postmortem analysis on the incident. We will document the response performed, the effectiveness of our response and update our SIEM detection rules, and Risk Register to avoid repetition.

Playbook: Compromised IAM Credential

Since a financial system is a sensitive area, stealing an IAM credential of an employee is an extreme threat. This situation is outlined in the playbook below.

1. Detection & Verification

- **Trigger:** One or more of the following indicators are raised, which is considered a trigger in the SIEM: multiple unsuccessful logins, an unusual login in a suspicious geographic area or an unusual API request (e.g., an effort to delete a backup database).

- **Action:** The Security Analyst tries to establish whether the activity is real by calling the IAM user via regular communication channels. An incident is proved in case they reject it or are inaccessible.

2. Containment

- **Action:** The Incident Responder connects with the administrative console.
- **Action:** Stop all the running IAM user sessions.
- **Action:** Turn off the Access Key ID and Secret Key that have been used in the suspicious activity.
- **Action:** Take the user to a very restricted IAM group having very strictly denied policies in place to make sure that no further actions can be performed by the user.

3. Analysis & Investigation

- **Action:** Query the SIEM and CloudTrail logs to allow auditing all the actions that the compromised credential performed.
- **Action:** Find out whether the intruder has accessed, changed, or stolen sensitive financial data or customer PII.
- **Action:** Determine what the first attack vector was (e.g., was the key left in a publicly available GitHub repository, or did the attacker phish the user?).

4. Eradication

- **Action:** Delete the impacted access keys forever.
- **Action:** In case the secret has been revealed in the source code, remove the secret and recreate the Git history.
- **Action:** Clean up any unauthorized infrastructure changes started by the attacker (e.g., delete EC2 instances or IAM roles created by the attacker).

5. Recovery

- **Action:** Generate a new and secure set of access keys for the user.
- **Action:** Make the user change their password.
- **Action:** Make sure Multi Factor Authentication (MFA) is correctly set up and is followed strictly on this user before restoring their access.

6. Lessons Learned

- **Action:** Hold a review meeting with the involved user and the security team.
- **Action:** Add a secret scanner to the CI/CD pipeline to ensure that any keys are not stored in repositories in the future.
- **Action:** Change the incident report and close the ticket.

Future Improvements & Recommendations:

To improve our security posture and reduce organizational risk, **we can implement:**

Automated Response: SOAR can be used to automate IAM containment to reduce the MTTR considerably.

Zero Trust Architecture: Move to an identity-centric architecture in which there is continuous verification of all Data Zone access.

Behavioral Analytics: Use machine learning in the SIEM to normalize behavior and identify high-level account takeovers.

Pipeline Security: Use secret scanning as part of the default CI/CD pipeline to avoid credential leakage in code.

The incident response workflow is a key element in preventing serious security breaches for our FinTech startup. Our group will have the tools to rapidly detect, analyze, and contain threats to ensure that attackers do not access sensitive financial information.

References

- Conklin, L., Drake, V., Strittmatter, S., Braiterman, Z., & Shostack, A. (n.d.). Threat modeling process. OWASP Foundation. https://owasp.org/www-community/Threat_Modeling_Process#stride
- Cybersecurity Insiders. (2024). *2024 Insider Threat Report [Gurukul]*.
<https://www.cybersecurity-insiders.com/portfolio/2024-insider-threat-report-gurukul/>
- Guevara, P. (2025, September 25). *A Guide to Understanding 5x5 Risk Assessment Matrix*. SafetyCulture. <https://safetyculture.com/topics/risk-assessment/5x5-risk-matrix>
- Moore, R. (2025, April 28). *6 major IT risk areas for fintech companies—and how to mitigate them*. RSM. <https://rsmus.com/insights/industries/financial-services/6-major-it-risks-for-fintech-companies.html>
- National Institute of Standards and Technology. (2006). *Guide to computer security log management (SP 800-92)*. U.S. Department of Commerce.
<https://csrc.nist.gov/publications/detail/sp/800-92/final>
- OWASP. (2025). *A02:2025 Security Misconfiguration*. OWASP Top 10:2025.
https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
- OWASP Foundation. (n.d.). *Authentication cheat sheet*.
https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html.
- Splunk. (n.d.). *Correlation searches and notable events*. Splunk Enterprise Security Documentation. [Notable events](#).

Splunk. (n.d.). *Using the Common Information Model*. Splunk Documentation. [Approaches to using the CIM](#)